THREAT ADVISORY

Citrix NetScaler Hit by Another SAML Zero-Day

Citrix has disclosed **CVE-2026-88779**, a SAML-related NetScaler zero-day under active exploitation. Affected systems may require another update even after recent patching, while possible code execution remains under investigation.

Sources: **Citrix CTX697174 · BleepingComputer** · 5 Oct 2026
CVE-2026-88779 · SAML / NetScaler ADC & Gateway

Memori CTI

ACTIVE EXPLOITATION / 5 OCTOBER 2026

NetScaler hit by another zero-day

Emergency fixes follow fresh attacks on SAML deployments, including appliances updated only days earlier.

For NetScaler administrators, the September patch cycle has led straight into another. Citrix has disclosed CVE-2026-88779 and is urging affected customers to update again.

The company confirms targeted attacks that can interrupt service. Researchers are also investigating possible code execution, but Citrix has not confirmed that impact for this CVE.

THIS WEEK

02 OCT

Citrix flags a new SAML issue.

03 OCT

Initial bulletin date in Citrix's Pacific-time changelog.

04 OCT

The CVE record and emergency-update coverage appear.

This brief covers CVE-2026-88779. Information current to 5 October 2026.

Citrix confirms a SAML denial-of-service flaw

A memory overflow in NetScaler ADC and Gateway can make the service unavailable. Repeated triggering can prolong the outage.

8.7

HIGH

CVSS v4.0
CWE-119

PUBLISHED VECTOR	ASSESSMENT
Attack path	Network
Privileges	None
User interaction	None
Attack complexity	Low
Availability impact	High

The authentication feature is exposed before login

The published vector requires neither an account nor user interaction. A device can therefore be exposed through its authentication path even though that path exists to control access.

EXPOSURE / SAML CONFIGURATION

The risk depends on how SAML is configured

The vendor links the issue to SAML authentication used with Gateway or AAA functionality. Either of the following roles meets the stated SAML condition.

SP

Service provider

```
add authentication samlAction
```

IdP

Identity provider

```
add authentication samlIdPProfile
```

These are configuration patterns to look for, not commands to run as an exposure test. Review matching objects and their virtual-server bindings.

Who installs the update?

Customers manage the affected ADC and Gateway instances, including those in Secure Private Access Hybrid. Citrix updates its managed cloud services and Adaptive Authentication.

REMEDIATION / FIXED BUILDS

Recently patched appliances need another update

The new SAML issue is separate from the vulnerabilities covered by CTX697096. Its fixed builds are newer than the September releases.

PRODUCT BRANCH	MINIMUM FIXED BUILD
ADC / Gateway 14.1	14.1-73.41
ADC / Gateway 13.1	13.1-64.28
ADC 14.1-FIPS	14.1-73.41 FIPS
ADC 13.1-FIPS / NDcPP	13.1-37.282

14.1-73.37 and 13.1-64.23 predate this fix.

After upgrading, confirm the running build on every node and test SAML sign-in. Keep the version evidence and the change time with the remediation record.

Later releases within the listed branch also qualify. Ask Citrix about unsupported branches or an appropriate migration path.

TEMPORARY MITIGATION / GLOBAL DENY LIST

Citrix offers temporary protection while teams patch

Global Deny List signatures can reduce exposure, provided the delivery settings and firmware conditions are met.

How signatures reach the appliance

Use NetScaler Console service or on-premises Console with Cloud Connect. Verify Virtual patching is enabled and, for on-premises Cloud Connect, Asset Delivery is selected.

Applicable ranges: 14.1-73.37 to before 14.1-73.41, and 13.1-64.23 to before 13.1-64.28.

Signature version

```
show appfw signatures
```

Under *Default Signatures, the Encrypted Version must be at least 24 for this advisory.

Rule activity

```
stat denylist global AAA_REQUEST
```

Review evaluation counters and Last Hit Time. Zero hits alone cannot show that protection is working.

These checks are read-only. Citrix still recommends installing the fixed software as soon as possible.

FIELD OBSERVATIONS / RCE INVESTIGATION

Researchers investigate possible code execution

The public evidence goes beyond routine restart complaints, but it leaves an important attribution gap.

An administrator investigating 14.1-73.37 devices described crafted authentication usernames containing commands to retrieve and run a payload. The requests appeared shortly before repeated nsaaad crashes.

That report establishes suspicious requests and correlated failures. Its author explicitly did not confirm successful command execution or identify a specific CVE as the cause.

Still under investigation

BleepingComputer also reports Kevin Beaumont finding a downloaded malware binary running on a patched honeypot.

Citrix's official classification remains DoS.

Attempted exploitation, observed execution and attribution to this CVE should remain separate findings in an incident record.

INCIDENT RESPONSE / POST-PATCH REVIEW

The investigation continues after patching

A fixed build closes the known exposure. It cannot establish what happened while the appliance was vulnerable.

The timeline	Record the configuration and installed build alongside the upgrade time. Preserve logs and coredumps before rotation or rebuilding removes evidence.
Beyond the appliance	Compare appliance failures and authentication events with firewall egress records and identity-provider logs. Look for activity that continues beyond the initial request.
The response	Unexpected binaries, outbound retrieval or unauthorized changes call for an incident investigation. Work with Citrix Support and the security team to decide on containment, rebuilding or credential rotation.

Analyst guidance: verify recovery on all nodes and document missing logs, the reviewed period and unresolved findings.

HUNTING REFERENCE

Indicators & hunting clues

A firsthand administrator report supplies these leads. It does not confirm successful exploitation of CVE-2026-88779.

OBSERVABLE	REPORTED CONTEXT
213.209.159[.]55	Payload destination. The incoming request source was not identified.
TCP 443 / HTTP	Plain HTTP retrieval on port 443.
/t/ and /v	Retrieval path prefix and intended local payload location.

The restart sequence

Correlate nsaaad exits with status 0x8a, Pitboss restart-limit events and reboots. Review /var/log/ns.log, rotated logs and /var/core.

An IP match is a lead to investigate. Missing files or negative searches cannot
exclude activity beyond the evidence still available.

No verified payload hash or CVE-specific detection rule is asserted here. Indicators reviewed 5 October 2026.

Stay vigilant. **Follow Memori CTI for more threat intel.**